

REDES Y SEGURIDAD II



Introducción

Ciberseguridad: definición UIT

- *Conjunto de herramientas, políticas, conceptos de seguridad, salvaguardas de seguridad, directrices, métodos de gestión de riesgos, acciones, formación, prácticas idóneas, seguros y tecnologías que pueden utilizarse para proteger los activos de la organización y los usuarios en el ciberentorno.*
 - *Los activos de la organización y los usuarios son los dispositivos informáticos conectados, los usuarios, los servicios/aplicaciones, los sistemas de comunicaciones, las comunicaciones multimedia, y la totalidad de la información transmitida y/o almacenada en el ciberentorno.*
- *Garantiza que se alcancen y mantengan las propiedades de seguridad de los activos de la organización y los usuarios contra los riesgos de seguridad correspondientes en el ciberentorno.*
- *Propiedades incluyen una o más de las siguientes:*
 - *Disponibilidad*
 - *Integridad (puede incluir la autenticidad y el no repudio)*
 - *Confidencialidad*



Tendencias en Seguridad

- La Seguridad es un concepto en continua evolución
- Las inversiones en esta área se incrementan año tras año debido a la gran adopción de las nuevas tecnologías
 - Información digital crítica
 - Procesos críticos
- Atacantes y defensores contribuyen a la mejora

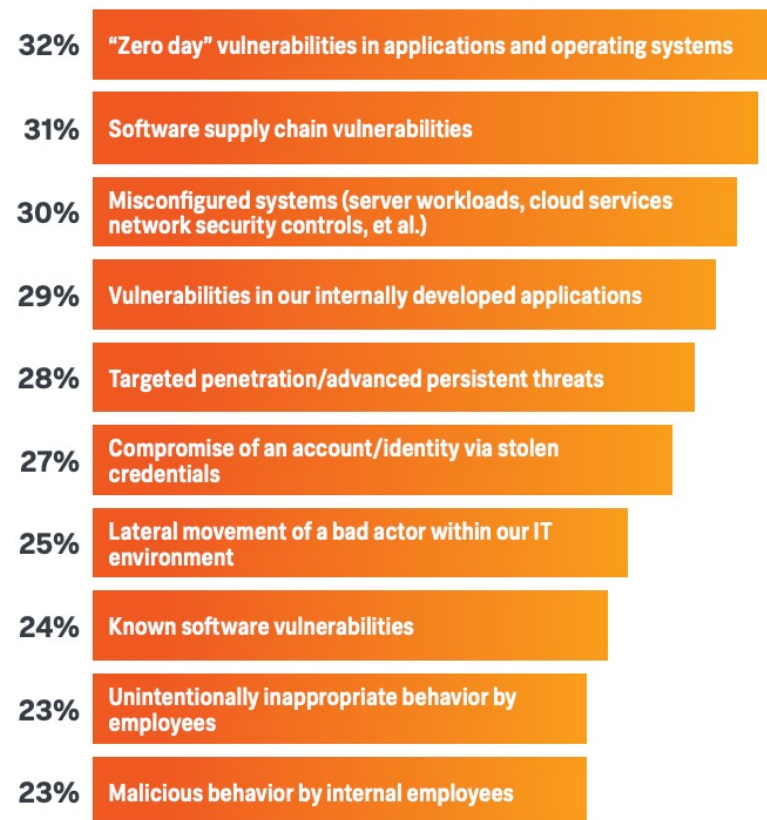




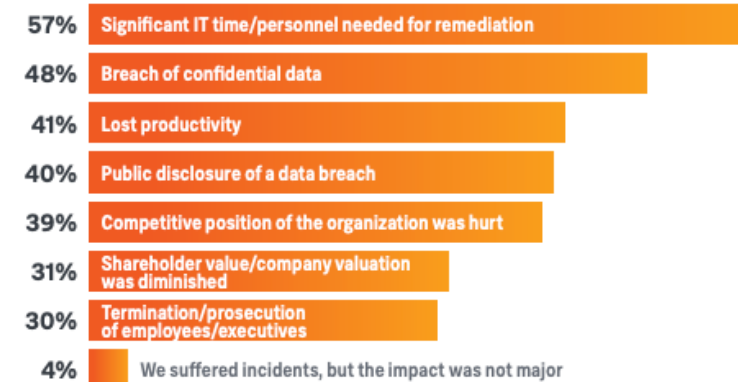
Tendencias en Seguridad



Most Concerning Threat Vulnerabilities



Effects of Incidents Over the Past Two Years



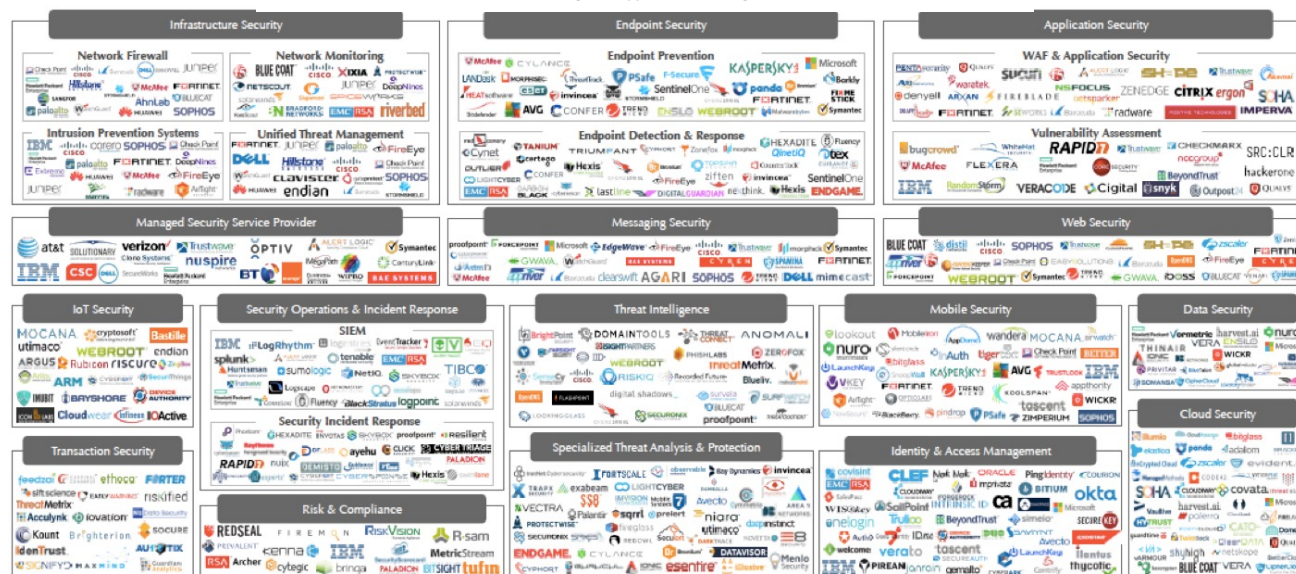
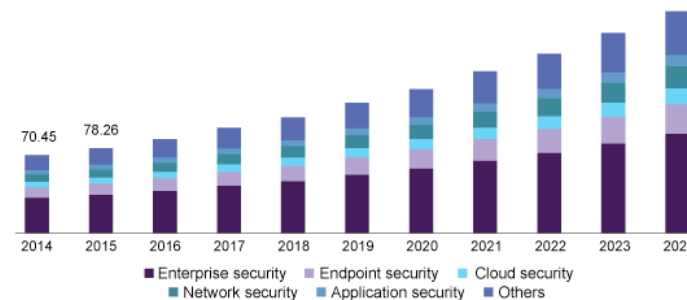
Incidents Experienced in the Past Two Years





Tendencias en Seguridad

Global cyber security market size, by security type, 2014 - 2024 (USD Billion)





Tendencias en Seguridad



Momentum Cyber's Snapshot Of 2022

Key Takeaways Across The Cybersecurity Industry.

13 \$1B+ M&A Deals Including

BROADCOM Acquires **vmware** \$69.2B
THOMABRAVO Acquires **@SailPoint** \$6.9B
Kaseya Acquires **datto** \$6.2B
opentext Acquires **MICRO FOCUS** \$5.7B
Google Acquires **MANDIANT** \$5.3B
VISTA Acquires **KnowBe4** \$4.3B
KKR Acquires **Barrauda** \$4.0B
THOMABRAVO Acquires **PingIdentity** \$2.8B
TA ASSOCIATES Acquires **VERACODE** \$2.5B

\$90M

Median 2022 Disclosed M&A Deal Value



MSSP Was The Most Active Sector In M&A With 46 Deals

2022 Had Record Deal Activity

\$119.8B

Total M&A Volume

\$18.5B

Total Financing Volume

2022 Was An Active Year

1,037 Financing Deals
263 M&A Deals



Risk & Compliance Was The Most Active Sector In Financing With 188 Raises

Public Markets Declined In 2022 Across Cyber



High Growth Cyber (42.4%)
 Low Growth Cyber (5.5%)
 HACK Index (28.1%)

Acquisitions Of Public Cyber Companies In 2022

datto KnowBe4 MANDIANT MICRO FOCUS
 PingIdentity @SailPoint tufin vmware

Private Equity's Cybersecurity

110 Deals Completed in 2022

Advent International KKR TA ASSOCIATES
 THOMABRAVO VISTA

15+ New Cybersecurity Unicorns Including

Abnormal BEYOND IDENTITY JupiterOne Material
 NORD perimeter 81 sonar Teleport

95 Capital Raises ≥ \$50M

Including

1Password Fireblocks sonar ARCTIC WOLF BlueVoyant
 \$620M \$550M \$412M \$401M \$250M
 CRITICALSTART Abnormal semperis AKONIS DRATA
 \$215M \$210M \$200M \$200M \$200M

Claves de un ataque exitoso

- **Sigilo:** el atacante permanece en el anonimato
- **Efectividad:** se cumple el objetivo trazado
- **Recompensa:** el resultado cumple las expectativas



Anatomía de un ataque

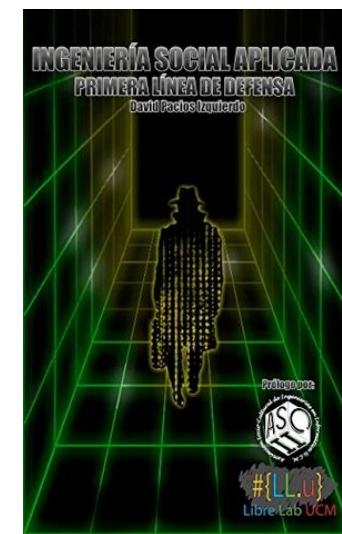
1. Footprinting

- Obtención de las características del objetivo
- Información:
 - Direcciones IP
 - Nombres de dominio
 - Sistemas de control de acceso
 - Sistema operativo
 - Arquitectura
- Un ataque exitoso depende en gran manera de esta fase



Anatomía de un ataque

- Mucha información está disponible online
 - Webs corporativas
 - Información de contacto de empleados
 - Foros (especialmente de los empleados despedidos)
- Esta información puede combinarse con métodos menos ortodoxos:
 - Ingeniería Social
 - Dumpster diving
 - Shoulder surfing



Anatomía de un ataque

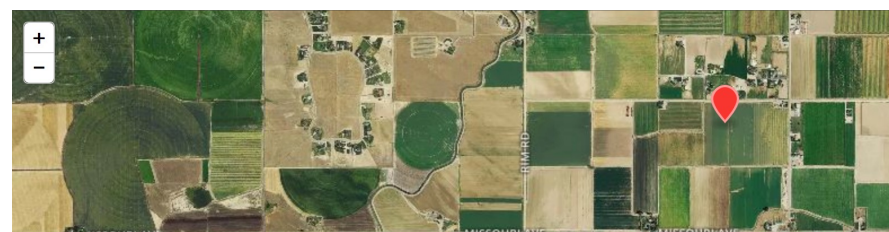
Ejemplos Shodan (el Google de las máquinas conectadas a Internet):

- *webcamxp*
- *authentication disabled has_screenshot:true country:ES*
- *org:"Universidad Complutense de Madrid"*



¿Es legal?

Operar desde Shodan sí lo es
Acceder a los servicios listados y
avanzar a través de ellos puede no serlo



self-signed	
City	Nampa
Country	United States
Organization	Cable One
ISP	Cable One
Last Update	2018-08-28T08:16:45.302935
Hostnames	24.118.126.87.cpe.cableone.net

Ports

80	443	8080	8081	8089
----	-----	------	------	------

Services

80
tcp
http

Apache httpd

HTTP/1.1 403 Forbidden
Date: Sun, 26 Aug 2018 14:07:00 GMT



Anatomía de un ataque

2. Scanning

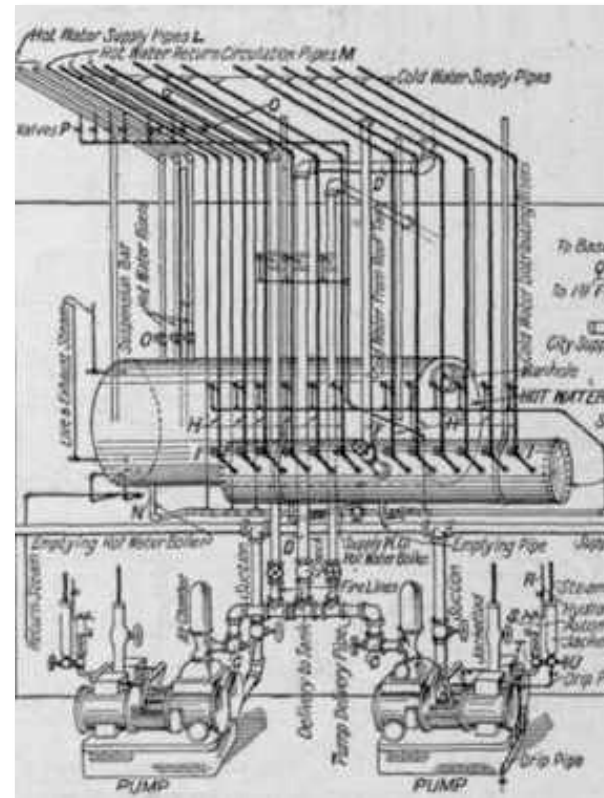
- Obtención en bloque de servicios desplegados por el sistema objetivo
- Se puede obtener información con la que no se pudo contar durante la fase anterior (ejemplo: sistema operativo)



Anatomía de un ataque

3. Enumeration

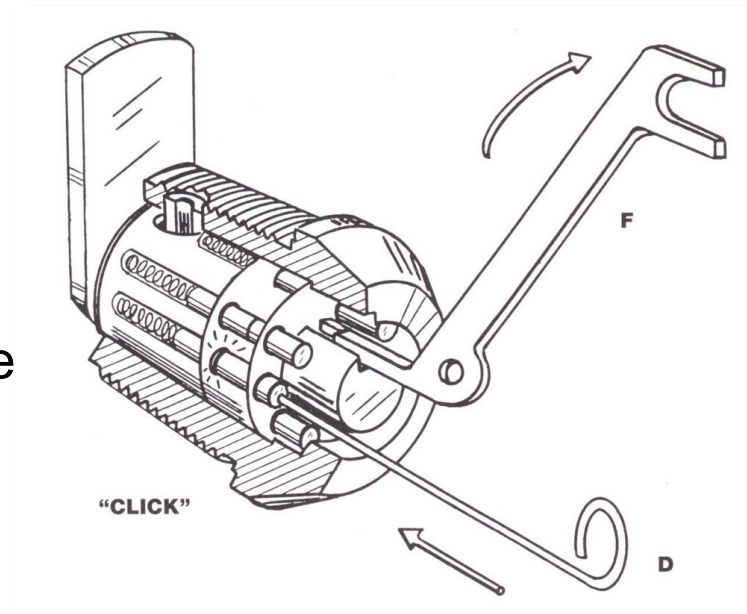
- Obtención de recursos interesantes que pueden ser usados para acceder al objetivo u obtener información vital
- Ejemplos:
 - Cuentas de usuario por defecto
 - Directorios compartidos



Anatomía de un ataque

4. Gaining access

- Acceso al sistema objetivo empleando la información obtenida anteriormente
- Puede ser necesario emplear más herramientas en esta fase (exploits, rastreadores de contraseñas)





Anatomía de un ataque

5. Privilege escalation

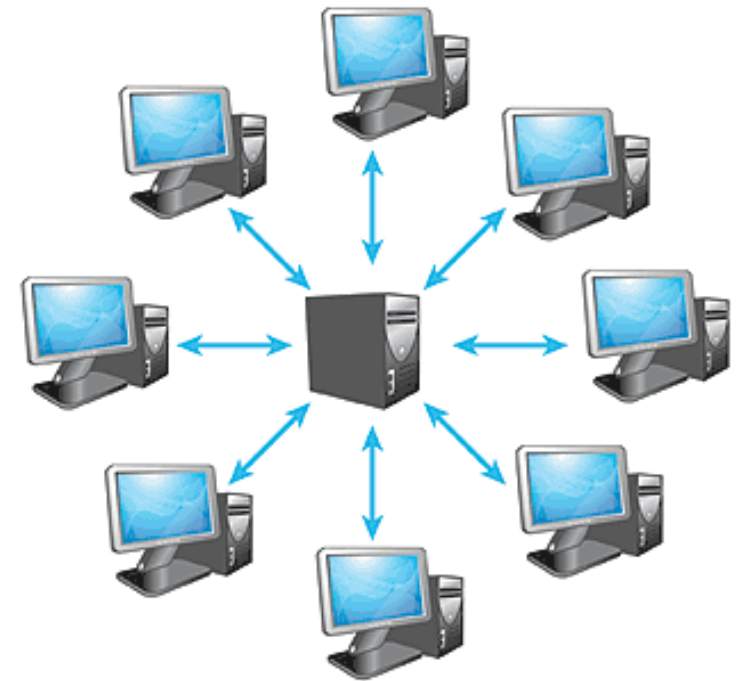
- Esta fase es necesaria cuando el acceso se realiza a una cuenta de usuario normal
- Obtención del control total del sistema objetivo (cuenta de superusuario/administrador)



Anatomía de un ataque

6. Pilfering

- Nueva obtención de información
- El objetivo son otros sistemas que no podrían ser accedidos desde otra localización



Anatomía de un ataque

7. Covering tracks

- Borrar cualquier registro de acceso del sistema
- Garantizar:
 - Anonimato del atacante
 - Desconocimiento de la intrusión por parte del propietario legítimo



Anatomía de un ataque

8. Creating back doors

- Garantizar que el acceso al sistema objetivo perdure en el tiempo
- Incluso tras un reinicio del sistema



Anatomía de un ataque

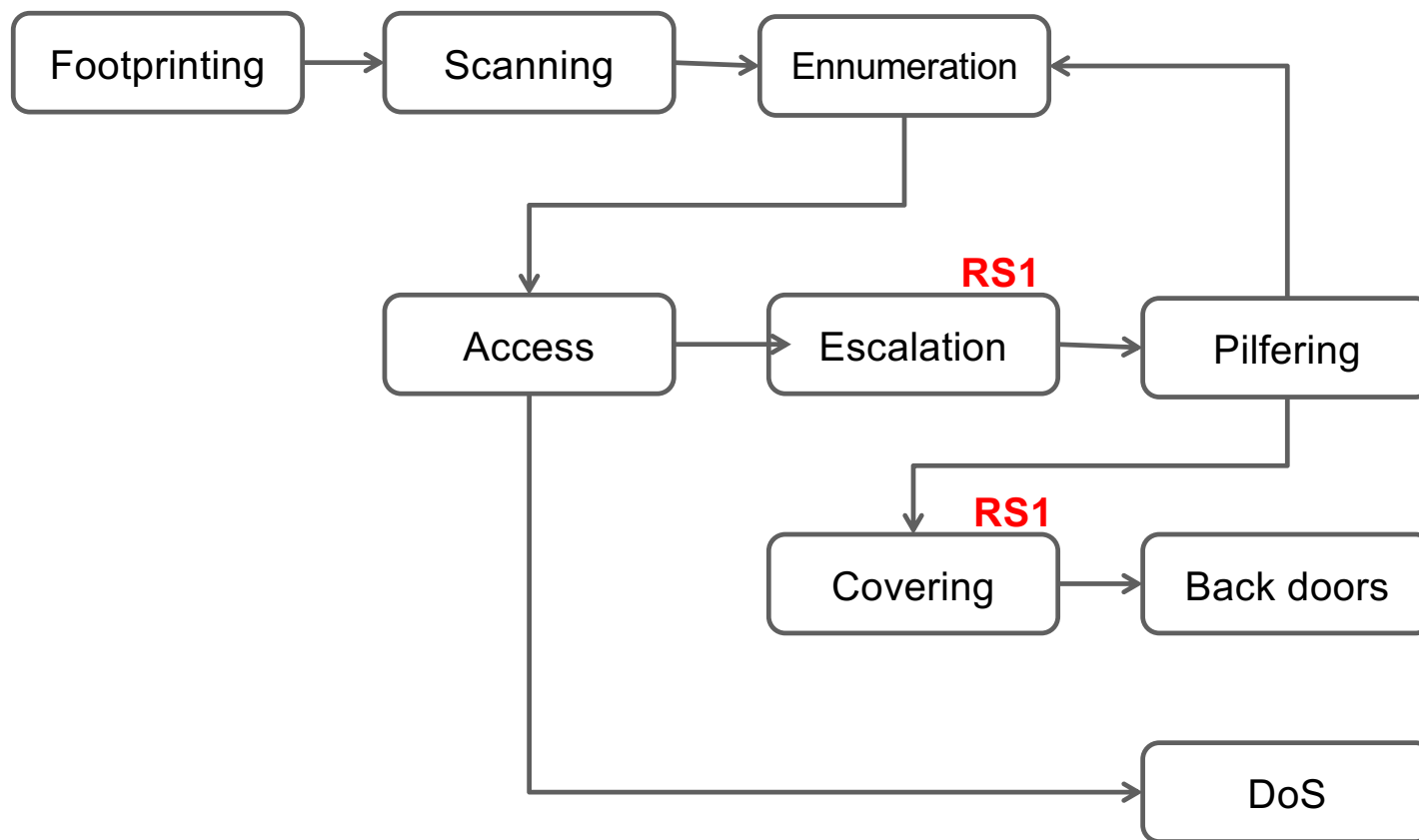
9. Denial of Service (DoS)

- Inhabilitación del sistema objetivo
- Puede ser parte de un ataque pero en general suele representar un fracaso del mismo





Anatomía de un ataque





Hacking Ético

Decálogo:

1. Informar sobre los posibles riesgos de realizar las pruebas
2. Establecer las responsabilidades de las consecuencias de las pruebas
3. Profesionalidad y calidad en el trabajo
4. Evitar el conflicto de intereses
5. Imparcialidad, neutralidad y transparencia de procesos
6. Respetar a los integrantes de la institución
7. No comprometerse con proveedores de soluciones de seguridad informática
8. Obediencia estricta a las leyes
9. Confidencialidad de los resultados
10. Citar las fuentes en el informe final

Hacking Ético

